

Mailing address:
Box 8114
104 20 Stockholm
Website:
www.imy.se
Email:
imy@imy.se
Phone:
08-657 61 00
1(8)

The Children and Education Committee of Östersund Municipality

Decision following supervision according to the
Data Protection Regulation - Children and
Education Committee of Östersund
Municipality

Decision of the Swedish Authority for Privacy Protection

The Swedish Authority for Privacy Protection (IMY) finds that the Children and Education Committee of Östersund Municipality (the Committee) has failed in its obligation under Article 35.1 of the Data Protection Regulation to conduct a Data Protection Impact Assessment (DPIA) before the service Google Workspace for Education (Google Workspace) began to be used in 24 of the municipality's schools in the autumn of 2020.

The Swedish Authority for Privacy Protection decides, based on Chapter 6, Section 2 of the Data Protection Act and Articles 58.2 and 83 of the Data Protection Regulation, that the Children and Education Committee of Östersund Municipality shall pay an administrative fine of 300,000 (three hundred thousand) Swedish kronor for the violation of Article 35.1 of the Data Protection Regulation.

Account of the supervisory case

The Swedish Authority for Privacy Protection (IMY) has initiated supervision of the Committee to examine whether the Committee has failed in its obligation under Article 35.1 of the Data Protection Regulation to conduct a Data Protection Impact Assessment before the service Google Workspace began to be used in 24 of the municipality's schools during the autumn of 2020.

In a statement to IMY on March 1, 2023, which was supplemented on March 23, 2023, the Committee has mainly stated the following.

In 2014, the Regional Federation of Jämtland County conducted a PUL assessment and risk analysis of Google Apps for Education, now Google Workspace for Education. In summary, it was concluded that the risk analysis did not indicate sufficient risks that would justify the operation refraining from using the cloud service. In May 2020, the municipality decided to migrate the service to its own domain, and in June 2020, the service was launched in the municipality's own IT environment. After the migration, the Committee has noted that the management has failed regarding the establishment of a new

1 Regulation (EU) 2016/679 of the European Parliament and of the Council of April 27, 2016, on the protection of natural persons with regard to the processing of personal data and on the free movement of such data, and repealing Directive 95/46/EC (General Data Protection Regulation).

2 The Act (2018:218) with supplementary provisions to the EU Data Protection Regulation.

Case number:

IMY-2023-1647

Your case number:

BOUN 00070-2023

Date:

2023-11-28

Swedish Data Protection Authority

Diary Number: IMY-2023-1647

2(8)

Date: 2023-11-28

consequence assessment as well as risk and vulnerability analysis. Although the assessment during the migration resulted in the same risks as identified in the analysis from 2014, documentation should have been established based on applicable legislation and the fact that the service was moved to its own domain. The authority has initiated a training effort for system administrators in the IT unit who work specifically with the service. At the time of the authority's statement, the training was halfway completed, and it could already be noted that the service had not been managed according to the instructions provided to the authority. Once the training is completed, the next step in the action plan is to conduct an audit of the service to clarify what security deficiencies exist in the system and thus obtain a basis for what measures need to be taken. The audit is part of the consultation in the consequence assessment that has been initiated. Since the audit has not been completed, the consequence assessment has not been either.

Google Workspace has been used at Östberg School and in 23 other schools in Östersund Municipality. The authority is the data controller for the processing of personal data in the use of the service in these schools. Google Workspace has been used for teaching and communication. Staff share planning and assignments with students, and students are given the opportunity to submit school assignments. During the pandemic, the Meet function has also been used to some extent to enable remote teaching. The service is also used for communication between educators and students in order to provide feedback regarding school assignments, for example, if something is missing, needs to be developed, supplemented, or similar. No summative assessments or grades are provided through the service. The service is also used for communication between students regarding school assignments. Some communication may also consist of more general information to students regarding lessons.

Personal data in the form of first name, last name, email address, class affiliation, and group affiliation are processed in the service. The service processes data about 5,945 students and 1,303 employees. The responsible class teacher can invite guardians, who can choose whether to accept or decline the invitation, to the service to access class assignments and weekly summaries. The current service was launched at the start of the school year 2020, academic year 2020/2021.

The authority did not conduct a consequence assessment prior to the implementation of the service, but it has been initiated, and the authority is now awaiting consultation (audit). The initiated consequence assessment also includes the question of whether the use of the service involves a transfer of personal data to a third country (i.e., a country outside the EU/EEA).

In connection with the final communication in the matter, the authority submitted a statement dated September 12, 2023, and stated among other things the following. The audit that was planned to be conducted at the time of the latest statement, as part of the consultation in the consequence assessment, has been completed. The security deficiencies identified in the audit have been addressed by the municipality. Given that the audit revealed many risks, there has been a significant need to work towards developing solutions as efficiently as possible, without compromising the quality and security of the work. Many of the measures are already in place. For example, the authority has signed an agreement with Google for an extended license, which includes that data is end-to-end encrypted, and allows the municipality's trained system administrators to work with the security settings required according to the completed audit. Likewise, many governing documents have been established, training programs are under development, information management plans have been updated, restrictions for storage/processing of information and personal data have been implemented, and stronger encryption efforts have been initiated. Subsequently, on November 7, 2023, the authority stated that

Swedish Authority for Privacy Protection

Diary Number: IMY-2023-1647

3(8)

Date: 2023-11-28

The impact assessment was essentially complete. What remained was a question regarding data flows.

Justification of the decision

Impact Assessment

Applicable provisions, etc.

The data controller is defined, according to Article 4.7 of the General Data Protection Regulation (GDPR), as a natural or legal person, public authority, agency, or other body that alone or jointly with others determines the purposes and means of processing personal data.

Article 35.1 of the GDPR states that if a type of processing, particularly using new technology and considering its nature, scope, context, and purposes, is likely to result in a high risk to the rights and freedoms of natural persons, the data controller must carry out an assessment of the impact of the planned processing on the protection of personal data, a so-called impact assessment, prior to the processing.

Recital 75 of the GDPR lists factors to be considered when assessing the risk to the rights and freedoms of natural persons. One factor that may be considered is whether the processing involves data concerning evaluations of personal aspects such as work performance. Furthermore, it should be considered whether the processing involves personal data about vulnerable natural persons, especially children, and concerns a large number of data subjects. Recital 76 of the GDPR states that the risk should be assessed based on an objective evaluation, which determines whether the processing involves a risk or a high risk.

Article 35.3 of the GDPR provides examples of situations where an impact assessment is required. Additionally, Article 35.4 of the GDPR states that the supervisory authority shall establish and publish a list of the types of processing operations that are subject to the requirement for such an impact assessment.

IMY has established such a list, see annex, which is based on the Article 29 Working Party guidelines. The list indicates that an impact assessment regarding data protection must be conducted if the planned processing meets at least two of the following criteria:

1. evaluates or scores individuals, for example, a company offering genetic testing to consumers to assess and predict risks of diseases, a credit reporting agency, or a company profiling internet users,
2. processes personal data for the purpose of making automated decisions that have legal effects or similarly significant effects on the data subject,
3. systematically monitors individuals, for example, through video surveillance of a public place or by collecting personal data from internet usage in public environments,

3 Diary Number DI-2018-13200

4 Guidelines on Data Protection Impact Assessment and determining whether processing "is likely to result in a high risk" within the meaning of Regulation 2016/679, adopted on April 4, 2017 (WP 248 rev. 01).

Swedish Authority for Privacy Protection

Diary Number: IMY-2023-1647

4(8)

Date: 2023-11-28

4. processes sensitive personal data according to Article 9 or data that is of a very personal nature, for example, a hospital storing patient records, a company collecting location data, or a bank handling financial information,
5. processes personal data on a large scale,
6. combines personal data from two or more processing activities in a way that deviates from what the data subjects could reasonably expect, for example, when cross-referencing registers,
7. processes personal data about individuals who, for some reason, are in a disadvantaged or dependent position and therefore vulnerable, such as children, employees, asylum seekers, the elderly, and patients,
8. uses new technology or new organizational solutions, for example, an Internet of Things (IoT)

application,

9. processes personal data with the aim of preventing data subjects from accessing a service or entering into a contract, for example, when a bank checks its customers against a credit information database to decide whether to offer them loans.

The list includes several examples of when two of the criteria should be considered fulfilled, and thus a consequence assessment must be conducted. In one of these examples, it is stated that consequence assessments should be carried out in the public sector prior to the processing of children's personal data in school activities, if there is a larger number of registered individuals (criteria 5 and 7).

Assessment by the Swedish Authority for Privacy Protection

The board has stated that it is the data controller for the processing of personal data that occurs when using the service Google Workspace in the relevant schools, which is supported by the investigation in the case. IMY notes that the board has determined the purpose and means of processing the personal data. The board is therefore the data controller for the relevant processing.

The investigation in the case shows that a previous version of the service, Google Apps for Education, was used by the board, but not on its own domain. The investigation further shows that Östersund Municipality, in May 2020, decided to migrate the new version of the service, Google Workspace, to its own domain and that the service was launched in the municipality's own IT environment in June 2020. During the autumn of 2020, the board began using the service in 24 of the municipality's schools. IMY assesses that the changes in the use of the service, which the municipality decided on in May 2020, resulted in a new processing of personal data by the board.

Article 35.1 of the General Data Protection Regulation states that if a type of processing is likely to result in a high risk to the rights and freedoms of natural persons, the data controller must carry out an assessment of the planned processing's impact on the protection of personal data, a so-called consequence assessment, prior to the processing. The question that IMY has to assess is whether there was an obligation to carry out a consequence assessment before the board commenced the processing of personal data in the autumn of 2020.

To determine which processing activities are likely to lead to a high risk, the supervisory authority, according to Article 35.4 of the General Data Protection Regulation, shall establish a list of processing activities for which a consequence assessment is required. IMY has as

Swedish Data Protection Authority

Diary Number: IMY-2023-1647

5(8)

Date: 2023-11-28

As mentioned above, a list has been established based on the Article 29 Working Party's guidelines. The list indicates that Data Protection Impact Assessments (DPIAs) must be conducted if a processing of personal data meets at least two of the criteria specified in the list. The list includes several examples of when two of the criteria should be considered fulfilled, and thus a DPIA must be conducted. One of these examples states that DPIAs should be performed in the public sector prior to the processing of children's personal data in educational activities, if there is a large number of registered individuals (criteria 5 and 7).

IMY notes that the processing in question is one that is specified in the aforementioned example. The processing is carried out in educational activities and concerns a large number of registered individuals who are primarily children. The children, as students, are in a vulnerable position in relation to the data controller. Furthermore, the processing has also involved employees who are in a dependent relationship with the authority. Additionally, the processing has partially included feedback on school assignments, which can be considered an evaluation of the registered individuals' performances.

IMY assesses that the processing in question, taking into account its nature, scope, context, and purpose, likely posed a high risk to the rights and freedoms of the registered individuals. The authority thus had an obligation to conduct a DPIA before the processing commenced in the autumn of 2020.

The investigation shows that the authority did not perform a DPIA before Google Workspace was used in the relevant schools in the autumn of 2020 and that the work to conduct a DPIA has not yet been

completed.

In light of this, IMY assesses that the authority has failed in its obligation under Article 35.1 of the General Data Protection Regulation (GDPR) to conduct a DPIA before the Google Workspace service was used in 24 schools in Östersund municipality during the autumn of 2020.

Choice of Intervention

Applicable Provisions

In cases of violations of the GDPR, IMY has several corrective powers available under Article 58.2 a–j of the GDPR, including reprimands, orders, and administrative fines.

Article 83.2 of the GDPR states that IMY shall impose administrative fines in addition to or instead of the other measures referred to in Article 58.2, depending on the circumstances of the individual case. Member States may establish rules regarding whether and to what extent administrative fines may be imposed on public authorities, as stated in Article 83.7 of the GDPR. According to Chapter 6, Section 2 of the Data Protection Act, IMY may impose fines on authorities for violations referred to in Articles 83.4, 83.5, and 83.6 of the GDPR, and Articles 83.1, 83.2, and 83.3 of the Regulation shall then apply.

Article 83.2 of the GDPR specifies the factors to be considered when deciding whether to impose administrative fines and when determining the amount of the fine. If it concerns a minor violation, IMY may, according to Recital 148 to

5 Diary Number DI-2018-13200

6 Guidelines on Data Protection Impact Assessment regarding whether the processing "likely leads to a high risk" in the sense intended in Regulation 2016/679, adopted on April 4, 2017 (WP 248 rev. 01).

Swedish Authority for Privacy Protection

Diary Number: IMY-2023-1647

6(8)

Date: 2023-11-28

The Data Protection Regulation issues a reprimand instead of imposing an administrative fine. The factors specified in Article 83.2 of the Data Protection Regulation shall also be considered when determining the amount of the administrative fine. Each supervisory authority shall ensure that the imposition of administrative fines in each individual case is effective, proportionate, and dissuasive. This is stated in Article 83.1 of the Data Protection Regulation.

An administrative fine shall be imposed

IMY has assessed that the board has failed in its obligation under Article 35.1 of the Data Protection Regulation to conduct a data protection impact assessment before the service Google Workspace was used.

IMY notes that the processing has involved 5,945 children, whose personal data is particularly worthy of protection, and that the data is processed in a context where the children, as students, are in a position of dependence on the data controller. Furthermore, IMY takes into account that the data protection impact assessment has not yet been completed despite approximately three years having passed since the processing began in the autumn of 2020. IMY further notes that the failure has involved a relatively high degree of negligence since it has been clear that the processing was subject to the requirement for a data protection impact assessment, among other things based on IMY's list according to Article 35.4. Therefore, IMY assesses that the board shall be imposed an administrative fine for the violation.

Amount of the administrative fine

For violations of, among other things, Article 35 of the Data Protection Regulation, the administrative fine for public authorities may amount to a maximum of 5,000,000 SEK. This is stated in Chapter 6, Section 2 of the Data Protection Act and Article 83.4 of the Data Protection Regulation. In determining the amount of the administrative fine, IMY shall consider the circumstances specified in Article 83.2 and ensure that the administrative fine is effective, proportionate, and dissuasive.

In assessing the seriousness of the violation, IMY considers in accordance with Article 83.2 g of the Data Protection Regulation that the processing has involved data about children, which is particularly

worthy of protection under the Data Protection Regulation. The processing has also partially involved particularly worthy data as feedback on school assignments.

Regarding the nature, severity, and duration of the violation according to Article 83.2 a of the Data Protection Regulation, the investigation shows that approximately three years have passed since the processing began without the board completing the data protection impact assessment. Furthermore, it appears that the processing has affected a large number of registered individuals, both students and employees. Additionally, the service has been used within the school – i.e., an activity where the registered student is in a position of dependence and vulnerable position in relation to the data controller. The processing has also concerned employees who are in a relationship of dependence towards the board.

IMY further notes that the board has been aware that it has not conducted a data protection impact assessment and that the board believes it should have conducted such an assessment. IMY notes that this failure has involved a relatively high degree of negligence since it has been clear that the processing was subject to the requirement for a data protection impact assessment, among other things based on IMY's list according to Article 35.4.

IMY further notes that the processing of personal data in a cloud service provided by an American company has likely posed a risk that the personal data is transferred to a third country without a level of protection that is substantially equivalent to the level guaranteed within the Union by the Data Protection Regulation unless specific protective measures are taken.

In addition to the assessment of the seriousness of the violation, IMY shall assess whether there are any aggravating or mitigating circumstances that may affect the amount of the administrative fine. The measures taken by the board after IMY initiated oversight, as stated in the statement from September 12, 2023, are not assessed by IMY as mitigating. This is because these are measures that the board should have established and implemented before the service began to be used. IMY assesses that there are no additional aggravating or mitigating circumstances, beyond those considered in the assessment of seriousness above, that affect the amount of the administrative fine.

Based on a comprehensive assessment of the circumstances in the case, IMY determines that the Children and Education Board of Östersund Municipality shall pay an administrative fine of 300,000 SEK. IMY assesses that this amount is effective, proportionate, and dissuasive.

IMY notes that the board has stated that the data protection impact assessment is essentially complete and that there are therefore no grounds to require the board to conduct a data protection impact assessment.

This decision has been made by Acting Director General Karin Lönnheden after presentation by lawyer Nina Hellgren. In the final processing, Legal Director David Törngren, lawyer Cecilia Agnehall, and unit manager Nidia Nordenström have also participated.

Karin Lönnheden, 2023-11-28 (This is an electronic signature)

Appendix

List according to Article 35.4 of the Data Protection Regulation
Information on payment of administrative fine

Copy to

The board's data protection officer
Swedish Authority for Privacy Protection
Case Number: IMY-2023-1647

8(8)

Date: 2023-11-28

How to Appeal

If you wish to appeal the decision, you must write to IMY. In your letter, specify which decision you are appealing and the change you are requesting. The appeal must be received by IMY no later than three weeks from the day you were informed of the decision. However, if you are a party representing the public interest, the appeal must be submitted within three weeks from the day the decision was announced. If the appeal is submitted on time, IMY will forward it to the Administrative Court in

Stockholm for examination.

You may email the appeal to IMY if it does not contain any privacy-sensitive personal data or information that may be subject to confidentiality. The authority's contact details are provided on the first page of the decision.